

NIST AI Risk Management Framework

What AI RMF 1.0 contains, how the GOVERN · MAP · MEASURE · MANAGE core works, and a practical checklist for applying it to GenAI, RAG, and agentic systems.

AI RMF 1.0

NIST AI 600-1 · Generative AI Profile

Trustworthy AI

Practical Checklist

01 — FOUNDATION

Govern

02 — CONTEXT

Map

03 — EVIDENCE

Measure

04 — ACTION

Manage

FOUNDATIONS

What the NIST AI RMF Is

A voluntary, structured framework for managing risks created by AI systems — for anyone who designs, develops, deploys, evaluates, procures, governs, or uses AI.

Why It Exists

AI can create benefits and also introduce risks to individuals, organizations, society, and the environment. The AI RMF gives teams a common language and a structured way to **identify, assess, prioritize, respond to, and document** those risks.

What the Framework Contains

FIVE CORE COMPONENTS

- **Part 1 — Foundations:** AI risk, audiences, lifecycle concepts, and characteristics of trustworthy AI.
- **Part 2 — The AI RMF Core:** GOVERN, MAP, MEASURE, and MANAGE.
- **Categories & subcategories** under each function, describing desired outcomes and risk-management activities.
- **The AI RMF Playbook** — suggested actions, references, and examples for operationalizing the Core.
- **Profiles** for specific technologies or sectors, including the NIST Generative AI Profile (NIST AI 600-1).

Important Characteristics

CHARACTERISTIC	WHAT IT MEANS
Voluntary	Tailor it to the organization; it is not a certification scheme.
Risk-based	Focus effort on the risks that matter most for the specific AI context.
Outcome-focused	Describes desired outcomes rather than prescribing one technology.
Lifecycle-oriented	Applies from planning and design through deployment, monitoring, and retirement.
Iterative	Repeat risk management as models, data, users, threats, laws, and context change.

CURRENT STATUS (AUG 2026) NIST states that AI RMF 1.0 is being revised. AI RMF 1.0 remains the published framework, and the Playbook is still based on it. Teams should check NIST directly for updates.

FOUNDATIONS

Trustworthy AI: What Should We Care About?

NIST does not treat AI risk as only a cybersecurity issue. Trustworthiness is socio-technical — risk comes from technology, data, people, process, organizational decisions, and the deployment environment.

Seven Trustworthiness Characteristics — AI RMF 1.0

Valid & Reliable Performs as intended and produces sufficiently accurate, consistent results.	Safe Avoids unacceptable harm to people, property, organizations, or the environment.
Secure & Resilient Withstands attacks, misuse, failures, and unexpected changes.	Accountable & Transparent Roles, decisions, limitations, and governance activities are documented and understandable.
Explainable & Interpretable Relevant actors can understand the basis, meaning, or limitations of outputs.	Privacy-Enhanced Privacy risks are considered across data, model use, outputs, logging, and monitoring.
Fair — Harmful Bias Managed Organizations evaluate and manage harmful bias and disparate impacts.	

Trade-Offs Are Normal

A system may improve one characteristic while creating tension with another. More logging can improve accountability but increase privacy exposure; stronger security can reduce usability. NIST expects organizations to **balance characteristics based on context**, not optimize any single one in isolation.

Worked Example — GenAI Customer-Support Assistant

Teams may need to evaluate **hallucination, harmful content, sensitive-data leakage, prompt-injection resilience, fairness across user groups, transparency of limitations, human escalation, and operational monitoring** — together, not as isolated checks.

THE CORE

Govern → Map → Measure → Manage

The Core is the practical heart of the AI RMF. GOVERN is cross-cutting and informs the other three functions; MAP, MEASURE, and MANAGE are iterative and can be revisited throughout the AI lifecycle.

The Four Functions

GOVERN	MAP	MEASURE	MANAGE
Policies, roles, accountability, risk culture, documentation, and governance.	Purpose, context, stakeholders, benefits, harms, dependencies, and risk sources.	Methods, metrics, tests, evaluations, uncertainty, and evidence.	Prioritize risk, choose treatment, apply controls, monitor residual risk, decide whether to proceed.

GOVERN → MAP → MEASURE → MANAGE → (continuous loop)

Think of It as a Continuous Loop

A practical interpretation: establish governance → understand context and risks → test and measure → act on results → monitor → return to earlier functions when something changes.

Not a rigid sequence. NIST states the functions are not a checklist or mandatory ordered sequence. Organizations can tailor and revisit them. In practice, teams often establish GOVERN, begin with MAP, then use MEASURE and MANAGE iteratively.

Lifecycle Connection

- **Before design** — define purpose, stakeholders, risk tolerance, legal constraints, and accountability.
- **During development** — evaluate data, model behavior, security, privacy, fairness, robustness, and documentation.
- **Before deployment** — review evidence, residual risk, human oversight, operational controls, and go/no-go criteria.
- **After deployment** — monitor incidents, misuse, drift, changes, feedback, and emerging risks.

THE CORE, IN DETAIL

Govern + Map: Foundation and Context

Two functions that set up everything downstream — organizational ownership, and a clear picture of the system in its real-world context.

Govern — Make AI Risk Management Part of the Organization

GOVERN creates the organizational foundation for the other functions: policies, processes, roles, accountability, culture, risk tolerance, documentation, and communication.

QUESTION	TYPICAL EVIDENCE	EXAMPLE
Who owns the system and risk?	Owner / RACI / approval	Product + security + legal + RAI roles
What policies apply?	AI / privacy / security policies	Rules for GenAI use, data, model changes
What risk is acceptable?	Risk appetite / thresholds	High-impact actions need human approval
How are changes governed?	Version / change log	Prompt, model, and tool changes reviewed
How are issues escalated?	Incident / escalation process	Unsafe output triggers incident handling

Map — Understand the AI System in Context

MAP establishes context before deciding what to measure or how to treat risk. A highly accurate system can still be risky if it is used in the wrong context or affects high-impact decisions.

MAP ACTIVITY	KEY QUESTIONS
Purpose & use	What problem is the AI solving? What uses are allowed or prohibited?
Users & affected parties	Who uses it? Who may be impacted even if they do not use it directly?
Data & dependencies	What data, models, APIs, RAG sources, tools, agents, or vendors does it depend on?
Harms & benefits	What can go wrong? Who could be harmed? What benefits are expected?
Context & environment	Where will it run? What legal, business, cultural, safety, or security constraints apply?
Risk prioritization	Which risks appear most significant and therefore need measurement first?

PRACTICAL REFERENCE USE

Before building a metric dashboard, use MAP to write a one-page **context record**: purpose, users, data, model, tools, deployment setting, expected benefits, failure modes, affected groups, and top risks. That record tells MEASURE what to test.

THE CORE, IN DETAIL

Measure + Manage: Test and Act

Turning mapped risks into hard evidence, and turning evidence into prioritized action.

Measure — Produce Evidence

MEASURE converts mapped risks into tests, metrics, evaluations, and documented evidence. The goal is to determine whether the AI system and its controls are adequate for the intended context.

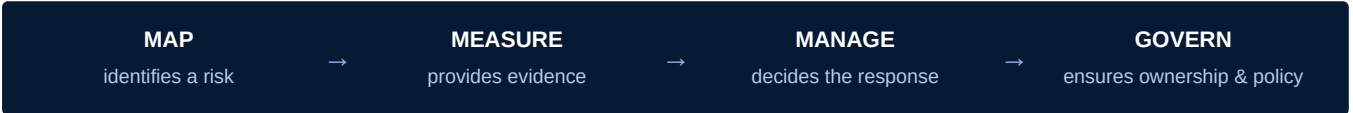
AREA	EXAMPLE EVIDENCE
Performance & reliability	Accuracy, task success, error rates, stability, regression results
Fairness	Group outcome comparisons, harmful-bias tests, accessibility impacts
Safety & content	Harmful output rates, refusal behavior, unsafe-completion testing
Security & resilience	Prompt injection, jailbreaks, data leakage, tool abuse, adversarial testing
Privacy	PII leakage, data minimization, retention, access control
GenAI quality	Groundedness, hallucination, citation integrity, relevance, robustness
Human factors	Override rates, escalation quality, operator understanding
Uncertainty	What cannot be measured reliably? What assumptions or limitations remain?

Manage — Decide What to Do

MANAGE takes MAP and MEASURE results and turns them into prioritized action: controls, ownership, residual risk decisions, deployment criteria, and ongoing monitoring.

- ▶ Prioritize risks using impact, likelihood, exposure, affected parties, and available controls.
- ▶ Choose treatment: avoid, reduce/mitigate, transfer/share, accept with justification, or stop the activity.
- ▶ Apply controls such as human approval, access restrictions, guardrails, grounding, rate limits, red-team testing, and incident response.
- ▶ Track residual risk after controls are applied — do not assume the control eliminated the risk.
- ▶ Re-evaluate when the model, data, prompt, toolset, vendor, users, or regulatory context changes.

Evidence Chain



PRACTICAL APPLICATION

How to Use AI RMF as a Practical Reference

A simple project workflow, notes on using the Playbook selectively, and the GenAI profile.

A Simple Project Workflow

- 1

Define the use case
Purpose, users, decision, model, data, tools, environment, and prohibited uses.
- 2

Establish governance
Owners, policies, risk tolerance, approval authority, documentation, escalation.
- 3

Map the risks
Bias, privacy, hallucination, security, unsafe output, excessive agency, misuse, operational failure.
- 4

Decide what to measure
Select metrics, evaluation sets, adversarial tests, human reviews, audits, or monitoring signals.
- 5

Measure and document
Run tests, record results and uncertainty, and retain evidence — including failed tests.
- 6

Manage and approve
Prioritize remediation, assign owners, document residual risk, define go/no-go criteria, obtain approval.
- 7

Monitor and revisit
Watch incidents, drift, new attacks, user feedback, model/vendor changes, and changing obligations.

Use the Playbook Selectively

The AI RMF Playbook provides suggested actions aligned to the Core. NIST states that it is **not a one-size-fits-all checklist** and is not meant to be implemented in full. Teams can select actions that fit their context and turn them into internal procedures, templates, technical guidance, or evidence requirements.

For Generative AI

NIST AI 600-1, the Generative AI Profile, is a companion resource for applying AI RMF 1.0 to GenAI. For LLMs, RAG, multimodal generation, or agentic systems, use the Core together with GenAI-specific risk guidance and actions.

Useful Project Artifacts

AI inventory entry

Use-case statement

Risk assessment

System / model card

Data / source register

Test plan

Fairness & safety evidence

Red-team results

Human oversight plan

Approval record

Monitoring plan

Incident log

Residual-risk register

WORKING REFERENCE

Practical NIST AI RMF Checklist

A practical internal aid derived from the AI RMF structure — not the NIST Playbook itself. Adapt to the organization, sector, risk level, and AI use case.

GOVERN

☐ Named business and technical owner.

☐ Applicable AI, security, privacy, legal, and compliance requirements identified.

☐ Risk tolerance / approval thresholds defined.

☐ Responsible AI, security, privacy, legal, operations, and oversight roles clear.

☐ Model, prompt, tool, data, and configuration changes governed and logged.

☐ Incident escalation and stop/rollback procedures defined.

MAP

☐ Purpose, users, affected parties, allowed uses, and prohibited uses documented.

☐ Data, models, APIs, RAG sources, tools, agents, and third parties inventoried.

☐ Potential benefits, harms, misuse, failure modes, and affected groups documented.

☐ Context-specific constraints and assumptions recorded.

☐ High-impact or consequential decisions identified.

☐ Top risks prioritized for measurement.

MEASURE

☐ Performance and reliability metrics defined.

☐ Fairness / harmful-bias checks performed where applicable.

☐ Privacy and sensitive-data leakage tested.

☐ Security testing covers prompt injection, jailbreaks, tool abuse, and data exposure where relevant.

☐ GenAI evaluated for grounding, hallucination, unsafe output, and citation/source integrity where relevant.

☐ Human oversight effectiveness tested; limitations and unmeasured risks documented.

MANAGE

☐ Risk treatment actions have owners and target dates.

☐ Controls applied to high-priority risks and effectiveness verified.

☐ Residual risks documented and accepted by the correct authority.

☐ Go/no-go deployment criteria defined and evidenced.

☐ Human approval required for high-impact actions where appropriate.

☐ Production monitoring, incident response, and re-assessment after material change established.

Reference Set

- NIST AI 100-1

— Artificial Intelligence Risk Management Framework (AI RMF 1.0), January 2023.
- NIST AI RMF Playbook

— companion suggested actions mapped to GOVERN, MAP, MEASURE, and MANAGE.
- NIST AI 600-1

— Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile, July 2024.
- NIST AI Resource Center (AIRC)

— operational resources, guidance, and testing/evaluation materials.

REMEMBER

Use AI RMF as a decision and evidence framework: understand the context, measure what matters, act on the evidence, document accountability, and repeat as the AI system changes.